Unified AI Governance & Security Portfolio

A practical board-level view of why AI needs governance, how the projects connect, and how they can mature into a unified AI oversight system.

Portfolio • Governance • Audit • Security • Policy

By : Rubin Fletcher

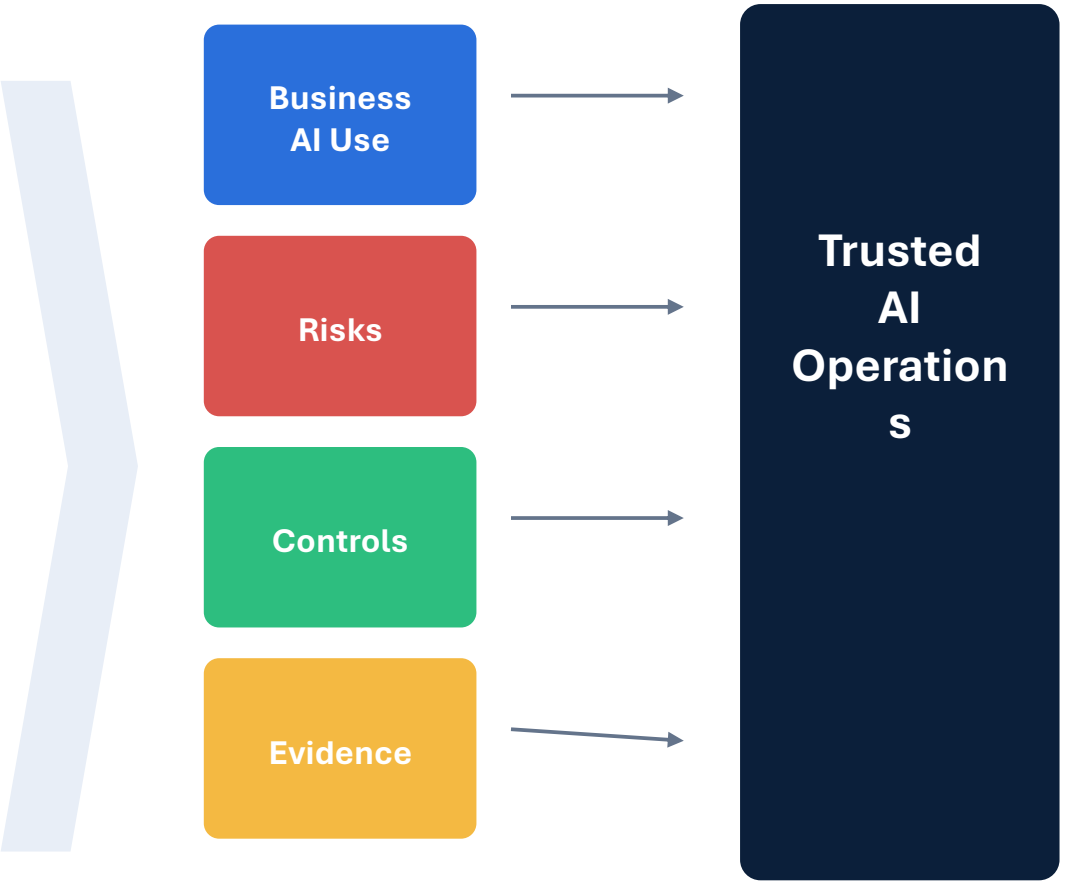
Prepared for executive, security, audit, and non-technical audiences

Why AI governance matters in plain English

Governance is the rulebook, ownership model, evidence trail, and safety system for AI use.

AI is not just software. It can influence decisions, expose data, automate work, summarize security alerts, shape hiring workflows, and affect customers or employees.

Without governance: different teams use different rules, data handling practices, approvals, and risk thresholds.
Without security: attackers can manipulate prompts, abuse access, poison data, or extract sensitive information.
Without audit evidence: leadership cannot prove AI is safe, fair, reviewed, monitored, or compliant.
With governance: every AI system has an owner, purpose, risk rating, controls, evidence, and review path.



Reference foundation: NIST AI RMF describes managing AI risks to individuals, organizations, and society; OWASP LLM Top 10 highlights LLM security risks.

The problem: fragmented AI oversight creates blind spots

Local AI rules can help a team move fast, but they break down when the organization needs consistency.

Fragmented approach

HR

Support

Security

Finance

Ops

Different approvals
Different logs
Different data handling
Different risk language
Different evidence quality

Unified approach

- Single AI inventory
- Common risk ratings
- Standard control library
- Evidence tracker
- Escalation + review board

Board value: a unified system lets leadership see the total AI risk picture instead of isolated local guesses.

Why America and the world need a unified AI governance model

AI crosses state lines, national borders, vendors, cloud platforms, and business units. Oversight should be interoperable.

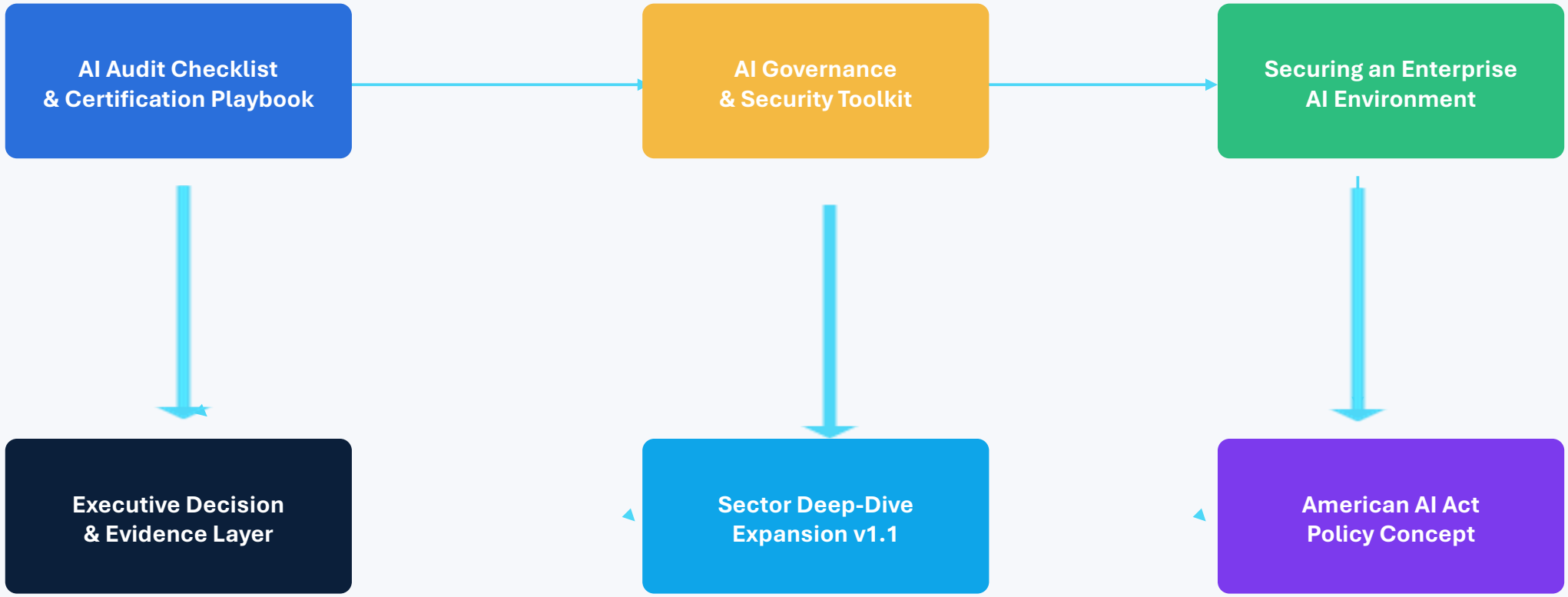
Challenge	What happens without a common model	What unified governance fixes
Cross-border systems	One AI tool may touch customers, employees, vendors, and cloud services in many jurisdictions.	Common controls, common evidence, and risk tiers that map to local laws.
State-by-state rules	Teams spend more time interpreting conflicting requirements than controlling real risk.	A baseline national/enterprise standard with sector add-ons.
Vendor ecosystem	Third-party models create hidden data, security, contract, and monitoring risks.	Standard vendor assurance and model use requirements.
Public trust	People lose confidence when AI decisions are opaque or inconsistent.	Human oversight, transparency, appeals, and documentation.

Unified governance does not mean one-size-fits-all. It means one foundation with sector-specific controls for healthcare, finance, defense, education, employment, public services, and critical infrastructure.

Context: EU AI Act creates harmonised rules for trustworthy AI in the EU; NIST AI RMF provides a common risk-management framework in the U.S.

Portfolio map: four connected building blocks

Each project answers a different executive question. Together they become an AI governance operating system.



Board questions answered

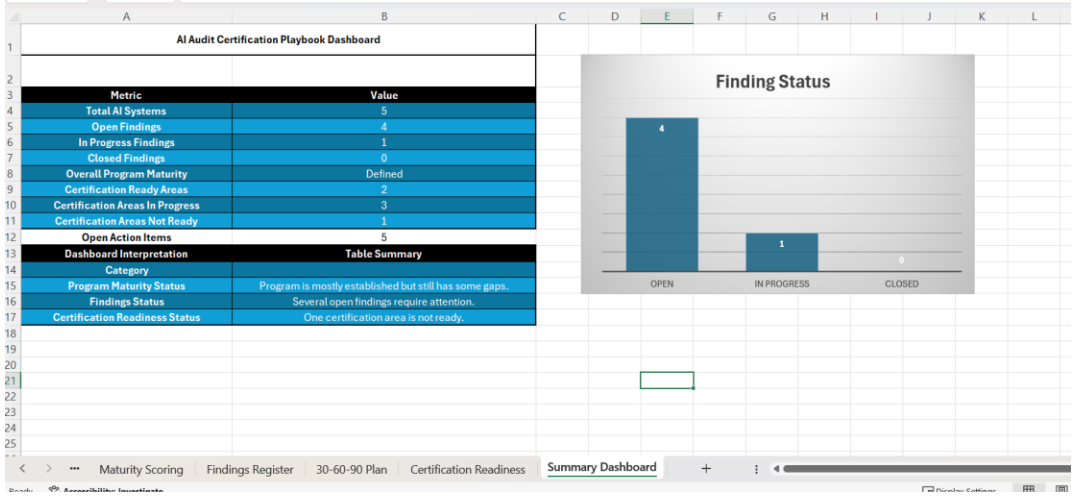
What AI do we have? What risk does it create? What controls are in place? Can we prove it? What should we improve next?

Project 1: AI Audit Checklist & Certification Playbook

Turns high-level frameworks into audit-ready checklists, workbook sections, and certification readiness evidence.

What it is

A practical AI audit and certification-readiness toolkit.
Built around NIST AI RMF, ISO/IEC 42001, ISO/IEC 23894, ISO/IEC 42005, NIST GenAI Profile, and EU AI Act basics.
Includes AI inventory, control testing, findings register, maturity scoring, 30-60-90 plan, certification readiness, and summary dashboard.

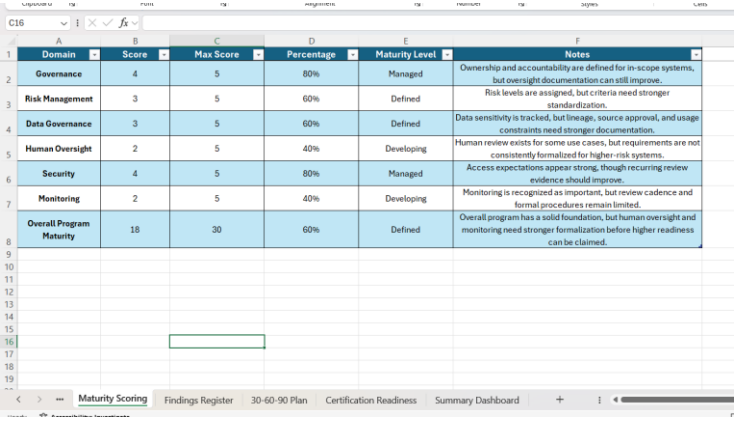


AI Audit Certification Playbook Dashboard

Metric	Value
Total AI Systems	5
Open Findings	4
In Progress Findings	1
Closed Findings	0
Overall Program Maturity	Defined
Certification Ready Areas	2
Certification Areas In Progress	3
Certification Areas Not Ready	1
Open Action Items	5
Dashboard Interpretation	**Table Summary**
Category	
Program Maturity Status	Program is mostly established but still has some gaps.
Findings Status	Several open findings require attention.
Certification Readiness Status	One certification area is not ready.

Why it matters

Executives need evidence, not just promises.
Auditors need repeatable testing logic.
Security and GRC teams need a common way to document risk, findings, and remediation.



Domain	Score	Max Score	Percentage	Maturity Level	Notes
Governance	4	5	80%	Managed	Ownership and accountability are defined for in-scope systems, but oversight documentation can still improve.
Risk Management	3	5	60%	Defined	Risk levels are assigned, but criteria need stronger standardization.
Data Governance	3	5	60%	Defined	Data sensitivity is tracked, but lineage, source approval, and usage constraints need stronger documentation.
Human Oversight	2	5	40%	Developing	Human review exists for some use cases, but requirements are not consistently formalized for higher-risk systems.
Security	4	5	80%	Managed	Access expectations appear strong, though recurring review evidence should improve.
Monitoring	2	5	40%	Developing	Monitoring is recognized as important, but review cadence and formal procedures remain limited.
Overall Program Maturity	18	30	60%	Defined	Overall program has a solid foundation, but human oversight and monitoring need stronger formalization before higher readiness can be claimed.

How the audit playbook works

The workflow creates a traceable path from inventory to readiness.

Inventory
List AI systems

→

Risk
Classify impact

→

Test
Validate
controls

→

Findings
Record gaps

→

Plan
30/60/90 actions

→

Readiness
Certification
view

Requirement Area	Status	Evidence Availabl	Gaps Identified	Owner	Target Completion Dat	Notes
Governance Structure	Ready	Yes	Minor documentation improvements remain	AI Program Lead	5/15/2026	Ownership and accountability are largely defined for in-scope systems.
Risk Assessment Process	In Progress	Yes	Risk scoring criteria need stronger standardization	Risk Manager	5/20/2026	Risk levels exist, but methodology needs to be more repeatable.
Data Governance Controls	In Progress	Partial	Data lineage, source approval, and usage constraints need stronger documentation	Data Owner	5/25/2026	Data classification is present, but documentation depth needs improvement.
Human Oversight Controls	Not Ready	Partial	Formal review requirements are not consistently documented for higher-risk systems	Compliance Lead	5/22/2026	Human oversight exists in practice, but policy and workflow requirements need formalization.
Security Controls	Ready	Yes	Recurring access review evidence should improve	Security Lead	6/5/2026	Access expectations appear strong, though evidence collection should mature.
Monitoring and Review	In Progress	Partial	Monitoring cadence and review procedures are not formalized across the program	Operations Lead	5/30/2026	Monitoring activities exist, but they are not yet consistent or well documented.

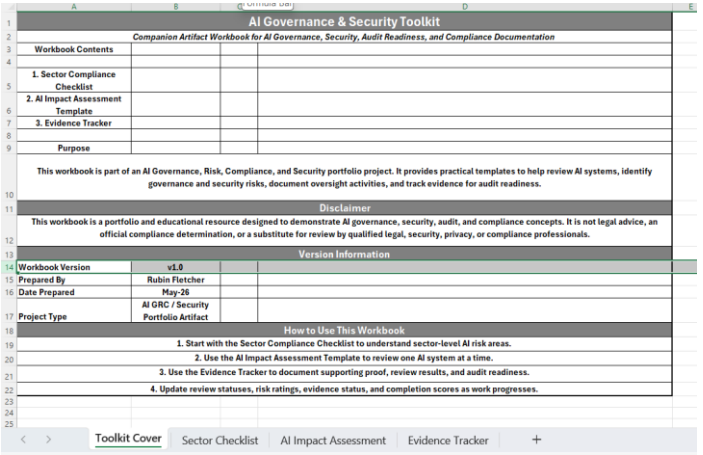
Output: an evidence-driven view of AI risk maturity, open findings, control testing status, and certification readiness.

Project 2: AI Governance & Security Toolkit

A practical Excel-based toolkit that turns responsible AI review into working business artifacts.

What it is

A portfolio-ready workbook that helps review AI systems across governance, security, privacy, fairness, transparency, and human oversight.
Includes a Sector Compliance Checklist, AI Impact Assessment, Evidence Tracker, and cover/instructions sheet.
Designed for technical and non-technical reviewers.



AI Governance & Security Toolkit

Companion Artifact Workbook for AI Governance, Security, Audit Readiness, and Compliance Documentation

Workbook Contents	
1. Sector Compliance Checklist	
2. AI Impact Assessment Template	
3. Evidence Tracker	
Purpose	

This workbook is part of an AI Governance, Risk, Compliance, and Security portfolio project. It provides practical templates to help review AI systems, identify governance and security risks, document oversight activities, and track evidence for audit readiness.

Disclaimer

This workbook is a portfolio and educational resource designed to demonstrate AI governance, security, audit, and compliance concepts. It is not legal advice, an official compliance determination, or a substitute for review by qualified legal, security, privacy, or compliance professionals.

Version Information

Workbook Version	v1.0
Prepared By	Rubin Fletcher
Date Prepared	May-26
Project Type	AI GRC / Security Portfolio Artifact

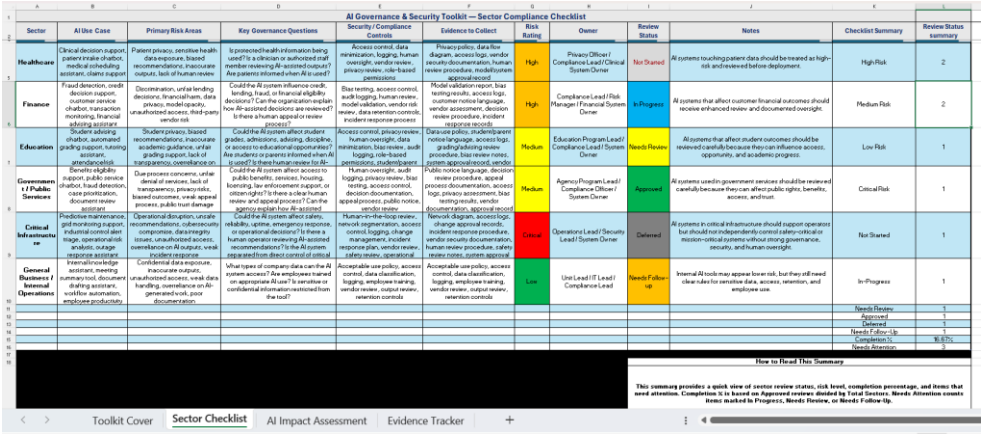
How to Use This Workbook

1. Start with the Sector Compliance Checklist to understand sector-level AI risk areas.
2. Use the AI Impact Assessment Template to review one AI system at a time.
3. Use the Evidence Tracker to document supporting proof, review results, and audit readiness.
4. Update review statuses, risk ratings, evidence status, and completion scores as work progresses.

Toolkit Cover | Sector Checklist | AI Impact Assessment | Evidence Tracker

The board value

Creates a repeatable review process before AI risk becomes an incident.
Helps leaders compare risk across sectors and use cases.
Turns “we think we are okay” into documented review and evidence.



AI Governance & Security Toolkit — Sector Compliance Checklist

Sector	AI Use Case	Primary Risk Areas	Key Governance Questions	Security / Compliance Controls	Evidence to Collect	Risk Rating	Owner	Review Status	Notes	Checklist Summary	Review Status summary
Healthcare	Clinical decision support, patient intake chatbot, medical scheduling assistant, claims support	Patient privacy, sensitive health data exposure, biased recommendations, inaccurate outputs, lack of human review	Is protected health information being used? Is a clinician or authorized staff member reviewing AI-assisted outputs? Are patients informed when AI is used?	Access control, data minimization, logging, human oversight, vendor review, privacy review, role-based permissions	Privacy policy, data flow diagram, access logs, vendor security documentation, human review procedure, model/system approval record	High	Privacy Officer / Compliance Lead / Clinical System Owner	Not Started	All systems touching patient data should be treated as high-risk and reviewed before deployment.	High Risk	2
Finance	Fraud detection, credit decision support, customer service chatbot, transaction monitoring, financial advising assistant	Discrimination, unfair lending decisions, financial harm, data privacy, model opacity, unauthorized access, third-party vendor risk	Could the AI system influence credit, lending, fraud, or financial eligibility decisions? Can the organization explain how AI-assisted decisions are reviewed? Is there a human appeal or review process?	Bias testing, access control, audit logging, human review, model validation, vendor risk review, data retention controls, incident response process	Model validation report, bias testing results, access logs, customer notice language, vendor assessment, decision review procedure, incident response records	High	Compliance Lead / Risk Manager / Financial System Owner	In-Progress	AI systems that affect customer financial outcomes should receive enhanced review and documented oversight.	Medium Risk	2
Education	Student advising chatbot, automated grading support, tutoring assistant, attendance risk	Student privacy, biased recommendations, inaccurate academic guidance, unfair grading support, lack of transparency, overreliance on	Could the AI system affect student grades, admissions, advising, discipline, or access to educational opportunities? Are students or parents informed when AI is used? Is there human review for AI-	Access control, privacy review, human oversight, data minimization, bias review, audit logging, role-based permissions, student/parent	Data use policy, student/parent notice language, access logs, grading/advising review procedure, bias review notes, system approval record, vendor	Medium	Education Program Lead / Compliance Lead / System Owner	Needs Review	AI systems that affect student outcomes should be reviewed carefully because they can influence access, opportunity, and academic progress.	Low Risk	1
Government / Public Services	Benefits eligibility support, public service chatbot, fraud detection, case prioritization, document review assistant	Due process concerns, unfair denial of services, lack of transparency, privacy risks, biased outcomes, weak appeal process, public trust damage	Could the AI system affect access to public benefits, services, housing, licensing, law enforcement support, or citizen rights? Is there a clear human review and appeal process? Can the agency explain how AI-assisted	Human oversight, audit logging, privacy review, bias testing, access control, decision documentation, appeal process, public notice, vendor review	Public notice language, decision review procedure, appeal process documentation, access logs, privacy assessment, bias testing results, vendor documentation, approval record	Medium	Agency Program Lead / Compliance Officer / System Owner	Approved	AI systems used in government services should be reviewed carefully because they can affect public rights, benefits, access, and trust.	Critical Risk	1
Critical Infrastructure	Predictive maintenance, grid monitoring support, industrial control alert triage, operational risk analysis, outage response assistant	Operational disruption, unsafe recommendations, cybersecurity compromise, data integrity issues, unauthorized access, overreliance on AI outputs, weak incident response	Could the AI system affect safety, reliability, uptime, emergency response, or operational decisions? Is there a human operator reviewing AI-assisted recommendations? Is the AI system separated from direct control of critical	Human-in-the-loop review, network segmentation, access control, logging, change management, incident response plan, vendor review, safety review, operational	Network diagram, access logs, change approval records, incident response procedure, vendor security documentation, human review procedure, safety review notes, system approval	Critical	Operations Lead / Security Lead / System Owner	Deferred	All systems in critical infrastructure should support operators but should not independently control safety-critical or mission-critical systems without strong governance, security, and human oversight.	Not Started	1
General Business / Internal Operations	Internal knowledge assistant, meeting summary tool, document drafting assistant, workflow automation, employee productivity	Confidential data exposure, inaccurate outputs, unauthorized access, weak data handling, overreliance on AI-generated work, poor documentation	What types of company data can the AI system access? Are employees trained on appropriate AI use? Is sensitive or confidential information restricted from the tool?	Acceptable use policy, access control, data classification, logging, employee training, vendor review, output review, retention controls	Acceptable use policy, access control, data classification, logging, employee training, vendor review, output review, retention controls	Low	Unit Lead / IT Lead / Compliance Lead	Needs Follow-up	Internal AI tools may appear low-risk, but they still need clear rules for sensitive data, access, retention, and employee use.	In-Progress	1
										Needs Review	1
										Approved	1
										Deferred	1
										Needs Follow-Up	1
										Completion %	16.67%
										Needs Attention	3

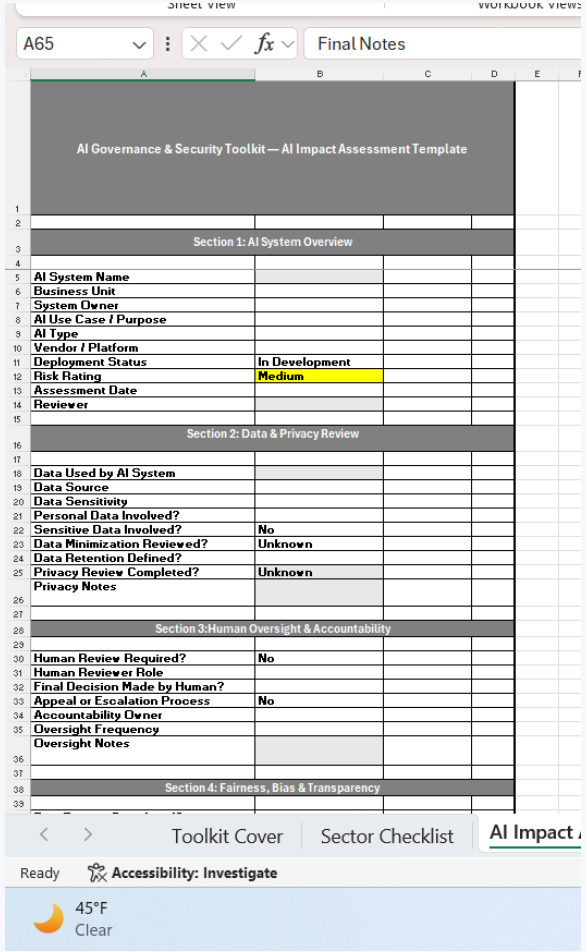
How to Read This Summary

This summary provides a quick view of sector review status, risk level, completion percentage, and items that need attention. Completion % is based on Approved reviews divided by Total Sectors. Needs Attention counts items marked In Progress, Needs Review, or Needs Follow-Up.

Toolkit Cover | Sector Checklist | AI Impact Assessment | Evidence Tracker

How the toolkit works

The toolkit supports both quick sector review and deeper one-system assessment.

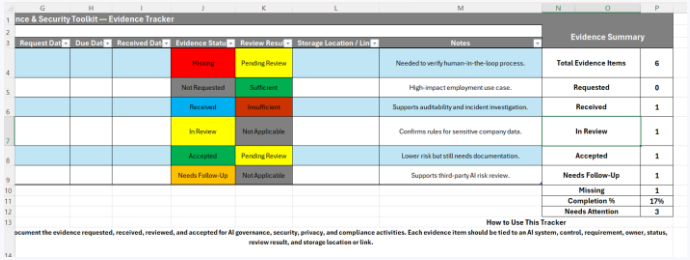


1	AI Governance & Security Toolkit — AI Impact Assessment Template	
2		
3	Section 1: AI System Overview	
4		
5	AI System Name	
6	Business Unit	
7	System Owner	
8	AI Use Case / Purpose	
9	AI Type	
10	Vendor / Platform	
11	Deployment Status	In Development
12	Risk Rating	Medium
13	Assessment Date	
14	Reviewer	
15		
16	Section 2: Data & Privacy Review	
17		
18	Data Used by AI System	
19	Data Source	
20	Data Sensitivity	
21	Personal Data Involved?	
22	Sensitive Data Involved?	No
23	Data Minimization Reviewed?	Unknown
24	Data Retention Defined?	
25	Privacy Review Completed?	Unknown
26	Privacy Notes	
27		
28	Section 3:Human Oversight & Accountability	
29		
30	Human Review Required?	No
31	Human Reviewer Role	
32	Final Decision Made by Human?	
33	Appeal or Escalation Process	No
34	Accountability Owner	
35	Oversight Frequency	
36	Oversight Notes	
37		
38	Section 4: Fairness, Bias & Transparency	
39		

Review logic

Start with the AI use case and business owner.
Review data sensitivity, privacy, human oversight, fairness, and transparency.
Check sector-specific concerns and escalation triggers.
Request evidence and track whether it is accepted, missing, or needs follow-up.

Decision: Approve, approve with conditions, defer, or escalate

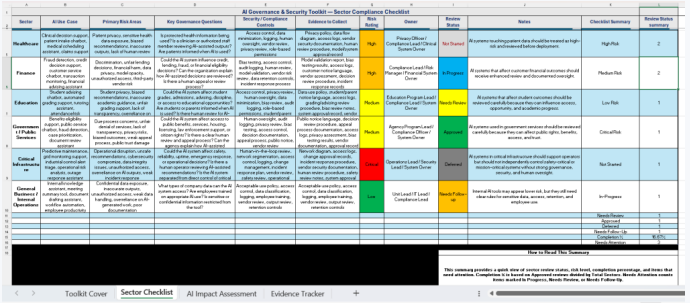


Request Date	Due Date	Received Date	Evidence Status	Review Result	Storage Location / Link	Notes
			Missing	Pending Review		Needed to verify human-in-the-loop process.
			Not Requested	Sufficient		High-impact employment use case.
			Received	Insufficient		Supports auditability and incident investigation.
			In Review	Not Applicable		Confirms rules for sensitive company data.
			Accepted	Pending Review		Lower risk but still needs documentation.
			Needs Follow-Up	Not Applicable		Supports third-party AI risk review.

Evidence Summary	
Total Evidence Items	6
Requested	0
Received	1
In Review	1
Accepted	1
Needs Follow-Up	1
Missing	1
Completion %	17%
Needs Attention	3

How to Use This Tracker

Document the evidence requested, received, reviewed, and accepted for AI governance, security, privacy, and compliance activities. Each evidence item should be tied to an AI system, control, requirement, owner, status, review result, and storage location or link.



AI Governance & Security Toolkit — Sector Compliance Checklist

Sector	Article Case	Primary Risk Areas	Key Governance Questions	Security / Compliance Controls	Evidence to Collect	Risk Rating	Owner	Review Status	Notes	Checklist Summary	Review Status summary
Healthcare	Clinical decision support, patient triage, chatbot, medical scheduling, insurance claims review	Patient privacy, sensitive health data exposure, biased recommendations, inaccurate outputs, lack of human review	Is protected health information being used? Is a clinician or authorized staff member reviewing AI-assisted output? Can the system explain its recommendation?	Access control, data minimization, human oversight, vendor review, privacy review, role-based permissions	Privacy policy, data flow diagram, access logs, security documentation, human review procedure, model/system approval records	High	Privacy Officer / Compliance Lead / Clinical System Owner	Not Started	AI summary routing patient data should be treated as high-risk and reviewed before deployment.	High Risk	2
Finance	Fraud detection, credit decision support, customer service chatbot, transaction monitoring, financial advisory, document extraction	Discrimination, unfair lending, financial harm, privacy, model drift, unauthorized access, third-party vendor risk	Could the AI system influence credit, lending, fraud, or financial eligibility decisions? Can the organization explain how AI-assisted decisions are reviewed? Is there a human override review process?	Bias testing, access control, model monitoring, vendor validation, vendor risk review, data retention controls, incident response process	Model documentation, bias testing results, access logs, customer notice/language, vendor assessment, decision review records, incident response records	High	Compliance Lead / Risk Manager / Financial System Owner	In Progress	AI systems that affect customer financial outcomes should receive enhanced review and documented oversight.	Medium Risk	2
Education	Student advising, chatbot, automated grading support, tutoring, admissions, attendance	Student privacy, biased recommendations, inaccurate academic guidance, unfair grading, lack of human review, transparency, consent or opt-out	Could the AI system affect student grades, admissions, advising, discipline, or access to educational opportunities? Is student data being used beyond its original purpose? Is there human review for disputes?	Access control, privacy review, human oversight, data minimization, bias review, audit logs, role-based permissions, student/parent notice	Data use policy, student/parent notice language, access logs, grading/advising review records, vendor review, system approval records, vendor documentation	Medium	Education Program Lead / Compliance Lead / System Owner	Needs Review	AI systems that affect student outcomes should be reviewed carefully because they can influence access, opportunity, and academic progress.	Low Risk	1
Government / Public Services	Benefits eligibility, document review, chatbot, fraud detection, case prioritization, document review assistant	Discriminatory decisions, opaque decisions, lack of human review, privacy risks, document processing errors, public trust damage	Could the AI system affect access to benefits, eligibility, enforcement, lending, law enforcement support, or citizen rights? Is there a clear human review and appeal process? Can the agency explain how AI-assisted decisions are made?	Bias testing, access control, human oversight, appeals process, public notice, vendor review	Public notice language, decision review records, access logs, vendor documentation, audit logs, privacy assessment, bias testing results, vendor documentation, approval records	Medium	Agency Program Lead / Compliance Officer / System Owner	Approved	AI systems used in government services should be reviewed carefully because they can affect public rights, benefits, access, and trust.	Critical Risk	1
Critical Infrastructure	Predictive maintenance, grid monitoring support, industrial control decision support, operational risk analysis, outage prediction, cybersecurity threat detection support	Operational disruption, unsafe recommendations, cybersecurity compromise, data integrity issues, unauthorized access, surveillance on AI outputs, weak human oversight	What type of company data can the AI system access? Are employees trained on appropriate AI use? Is sensitive or confidential information restricted from the tool?	Role-based access control, data classification, logging, employee training, vendor review, output review, retention controls	Access logs, security documentation, change approval records, incident response procedure, vendor security documentation, human review procedure, safety testing results, vendor review	Critical	Operations Lead / Security Lead / System Owner	Deferred	AI systems in critical infrastructure should support operators but should not independently control safety-critical or mission-critical systems without strong governance, security, and human oversight.	Not Started	1
General Business / Internal Operations	Meeting summary, knowledge assistant, meeting transcription, document drafting assistant, workflow automation, employee productivity	Confidential data exposure, inaccurate outputs, unauthorized access to data, handling, surveillance on AI-generated work, poor documentation	What type of company data can the AI system access? Are employees trained on appropriate AI use? Is sensitive or confidential information restricted from the tool?	Role-based access control, data classification, logging, employee training, vendor review, output review, retention controls	Acceptable use policy, access control, data classification, logging, employee training, vendor review, output review, retention controls	Low	Unit Lead / IT Lead / Compliance Lead	Needs Follow-up	Internal AI tools may appear lower risk, but they still need clear rules for sensitive data, access, retention, and employee use.	In Progress	1
										Needs Review	1
										In Progress	1
										Deferred	1
										Needs Follow-Up	1
										Completion %	16.67%
										Needs Attention	3

How to Read This Summary

This summary provides a quick view of sector review status, risk level, completion percentage, and items that need attention. Completion % is based on Approved reviews divided by Total Sectors. Needs Attention counts items marked in Progress, Needs Review, or Needs Follow-Up.

Toolkit Cover | Sector Checklist | AI Impact Assessment | Evidence Tracker

Project 3: Securing an Enterprise AI Environment

Security translates governance expectations into access controls, monitoring, incident response, and technical defense.

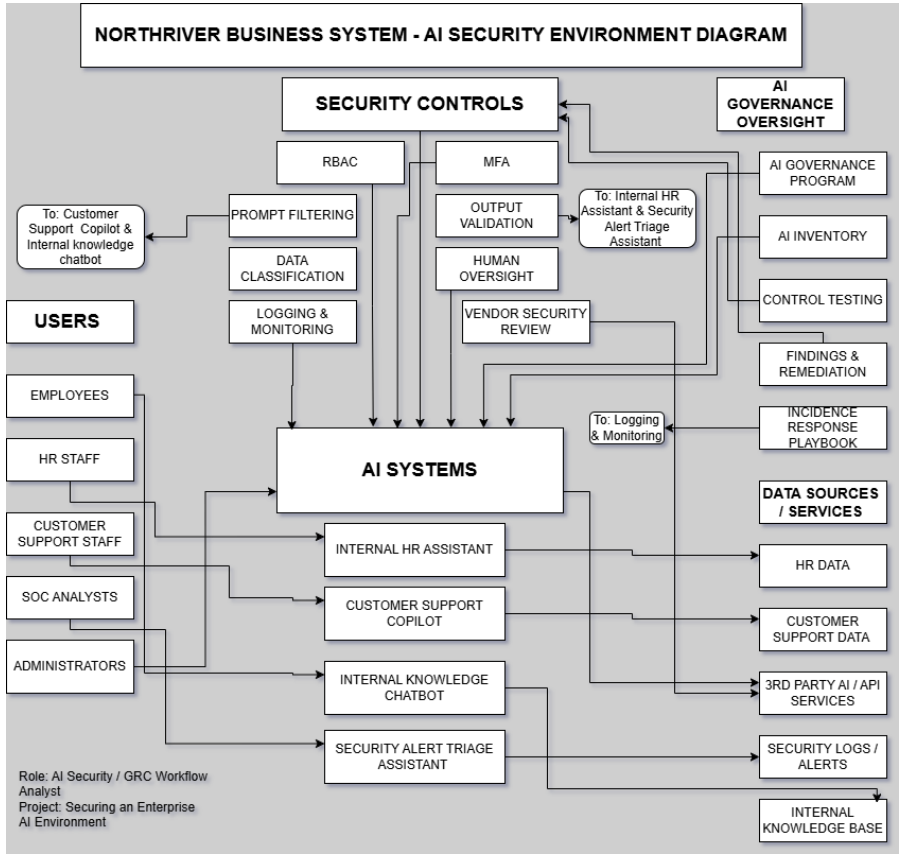
Scenario

NorthRiver Business Systems is a fictional mid-sized company using AI for HR support, customer support, security alert triage, and internal knowledge support.

Primary risk areas

Unauthorized access to AI tools and connected data.
Sensitive data leakage through prompts, outputs, logs, or integrations.
Prompt injection and input manipulation.
Insecure third-party AI services and vendor dependencies.
Weak monitoring, logging, and incident response.

Security objective: protect AI systems while still enabling responsible innovation.

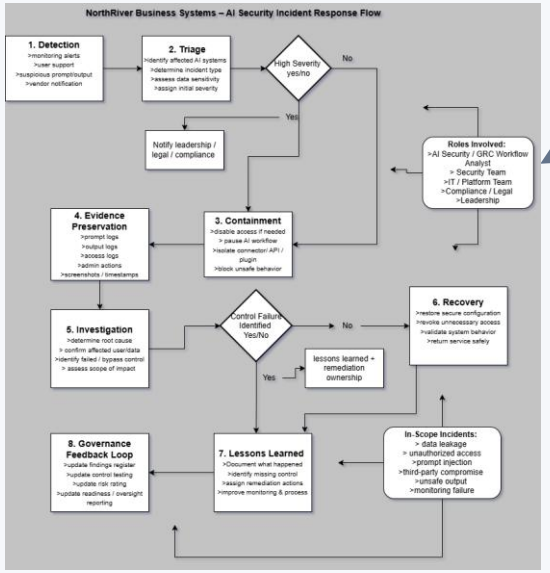


How the AI security project works

Threat model → control matrix → test plan → incident response flow.

Threat ID	Threat Scenario	Affected System / Asset	Threat Actor	Likelihood	Impact	Risk Level	Planned Mitigation / Control	Owner	Status
TM-01	Unauthorized access to internal AI tools due to weak access control	All in-scope AI systems	External attackers / unauthorized internal user	Medium	High	High	Enforce RBAC, MFA, periodic access review, and admin separation	IT Security Manager	Open
TM-02	Sensitive employee information exposed through AI prompts or outputs	Internal HR Assistant / HR Data	Internal User / careless employee	Medium	High	High	Apply data classification, output review, prompt handling guidance, and restricted access	HR Systems Manager	Open
TM-03	Prompt injections cause the chatbot to ignore restrictions or reveal internal information	internal Knowledge chatbot / Knowledge base	Malicious User	High	High	High	Implement prompt filtering, input validation, content restrictions, and monitoring	AI Application Owner	Open
TM-04	Customer account data is exposed through AI-assisted response drafting	Customer Support Copilot / Customer Support Data	Internal user / external attacker	Medium	High	High	Enforce human review, data protection controls, logging, and least privilege access	Support Operations Lead	Open
TM-05	Suspicious or compromised account activity affects security AI workflows	Security Alert Triage Assistant / Security Logs	External attacker / compromised insider account	Medium	High	High	Require MFA, privileged access control, logging, and alert review for abnormal behavior	SOC Manager	Open
TM-06	Third-party AI or API provider introduces downstream security risk	Third-Party AI / API Services	Vendor compromise / third-party failure	Medium	High	High	Perform vendor security review, contract review, and periodic reassessment	Vendor Risk Manager	Open

Control ID	Control Domain	Control Objective	Security Control	Applies To	Risk Addressed	Owner	Implementation Status	Priority	Notes
AIS-02	Identity and Access Management	Strengthen authentication for sensitive AI systems	Require MFA for users and administrators accessing AI systems	All in-scope AI systems	Account compromise	IT Security Manager	Planned	High	Especially important for administrative and high-impact systems
AIS-03	Identity and Access Management	Limit privileged activity	Separate admin roles from standard user roles and review privileged access regularly	All in-scope AI systems	Excessive permissions	IT Security Manager	Planned	High	Supports accountability and reduces misuse risk
AIS-04	Data Protection	Protect sensitive data from improper use	Classify data used in prompts, outputs, and connected knowledge sources	HR Assistant, Customer Support Copilot, Internal Knowledge Chatbot	Sensitive data leakage	Data Governance Lead	Planned	High	Helps determine handling and protection requirements
AIS-05	Data Protection	Reduce exposure of regulated or confidential data	Prohibit entry of restricted data into unapproved public AI tools	All in-scope AI systems	Data leakage to external tools	Compliance Lead	Planned	High	Requires policy and user awareness support
AIS-06	Data Protection	Protect stored AI-related records	Encrypt prompt logs, output logs, and connected data stores where appropriate	All in-scope AI systems	Unauthorized data access	Platform Security Lead	Planned	Medium	Especially important for logs containing sensitive records
AIS-07	Model and Application Security	Reduce prompt-based manipulation	Implement prompt filtering, input validation, and content restriction controls	Customer Support Copilot, Internal Knowledge Chatbot	Prompt injection	AI Application Owner	Planned	High	One of the most important AI-specific co



Threat matrix identifies what can go wrong. Control matrix defines what should stop it. Incident response flow shows what to do when something happens.

Policy concept: American AI Act idea

A proposed policy framework that balances innovation with safety, accountability, and sector-based protections.

Core idea

Create a national baseline so organizations do not have to guess across many conflicting local AI rules.
Use risk tiers so low-risk AI is not overburdened, but high-impact AI gets stronger controls.
Protect people, workers, customers, and national interests without freezing American innovation.

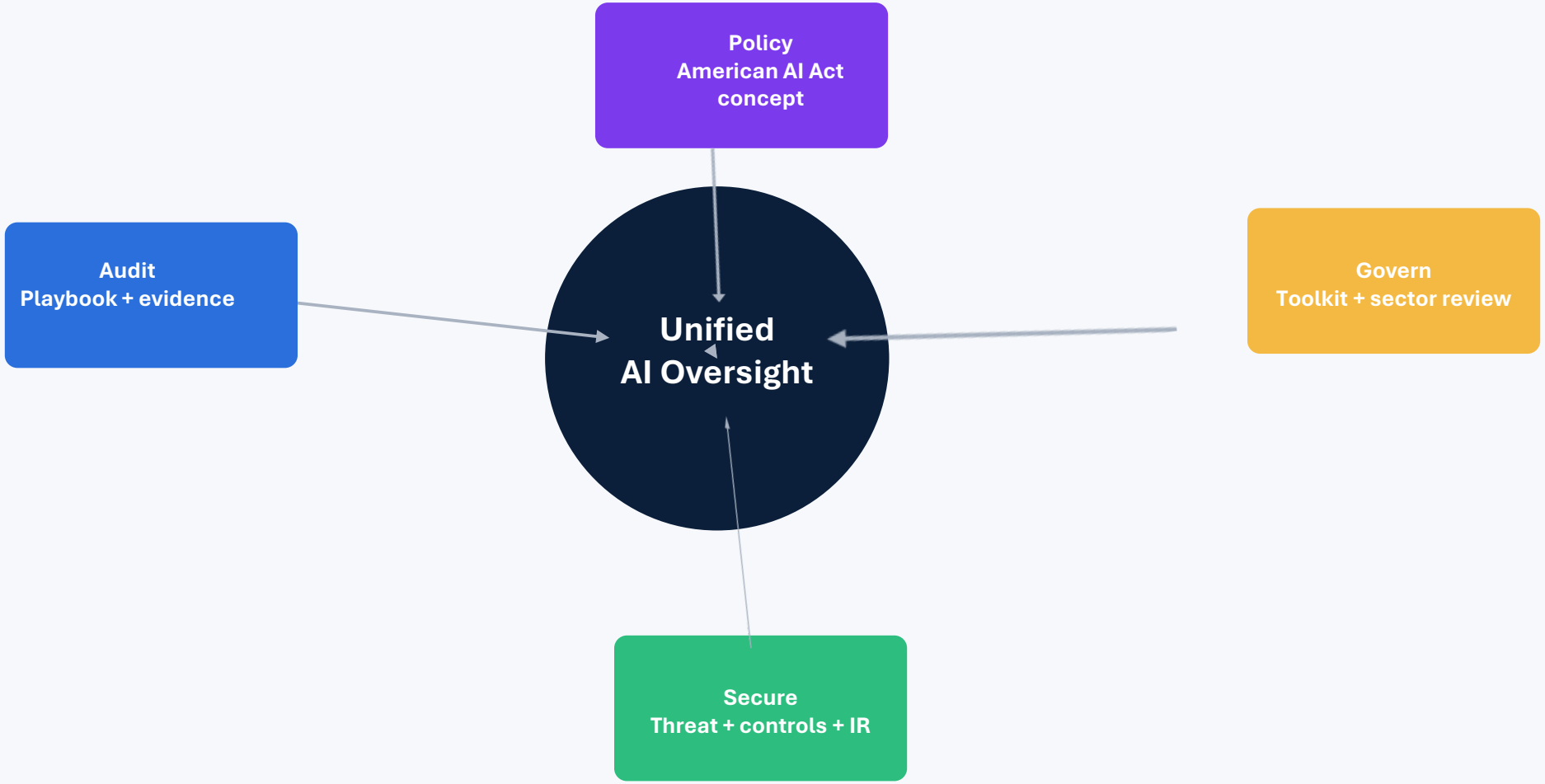
Principles

Human oversight for high-impact decisions.
Documented risk assessment and evidence.
Sector-specific safeguards for sensitive areas.
Vendor accountability and data protection.
Security-by-design for AI systems.

The policy idea strengthens the portfolio by explaining the “why” behind the audit, toolkit, and security controls.

How the projects work together as one system

The value is in the connections: policy sets direction, governance organizes work, audit proves it, and security defends it.



System behavior Inventory feeds risk assessment → risk drives controls → controls require evidence → evidence informs board decisions → policy improves the next cycle.

Executive view: how much AI governance do we actually need?

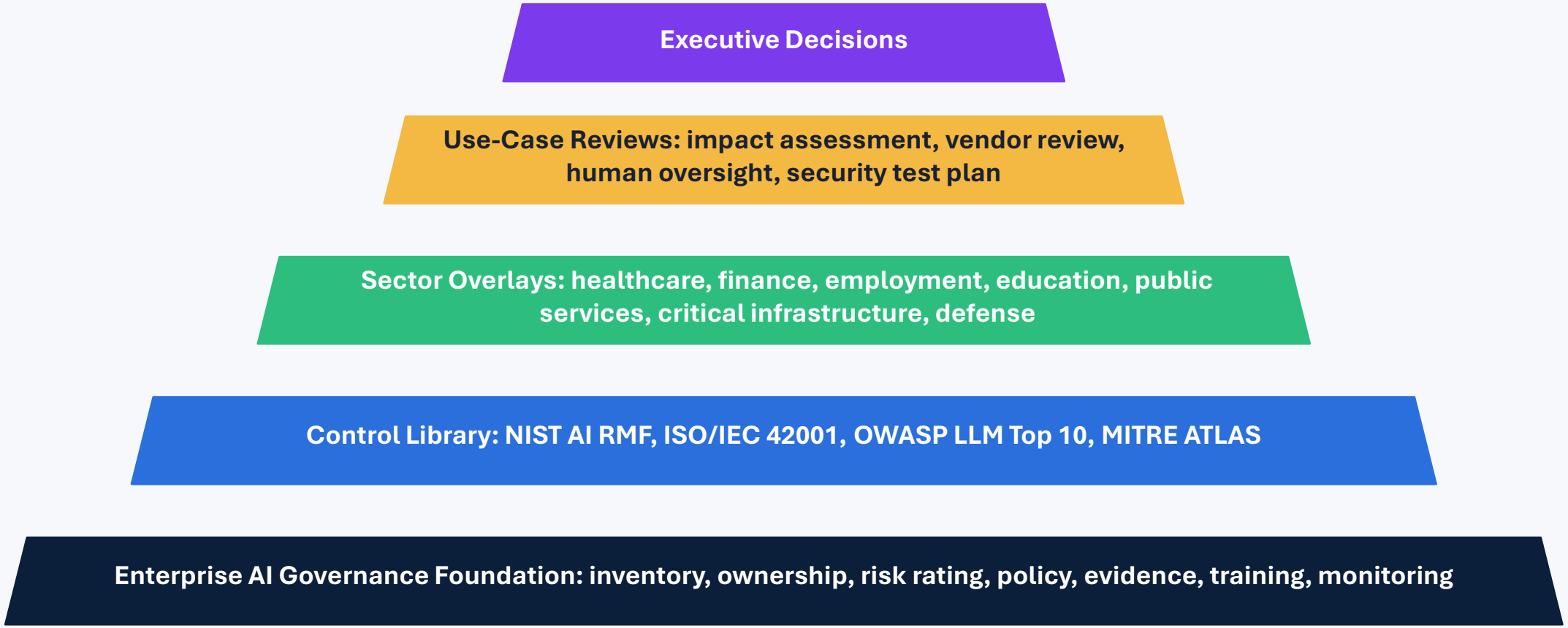
A risk-tiered model keeps oversight proportional. Not every AI use case needs the same control depth.

Low	**Examples: grammar help, internal brainstorming**	Light review, user guidance, acceptable use rules
Medium	**Examples: customer support drafting, internal knowledge chatbot**	Owner, impact assessment, logging, human review, evidence
High	**Examples: HR, security triage, finance, healthcare, critical infrastructure**	Formal approval, testing, access controls, monitoring, incident response, periodic audit
Critical	**Examples: defense, public safety, mission-critical operations**	Board visibility, independent review, strict controls, red-team testing, legal/security sign-off

Board takeaway: most companies do not need bureaucracy; they need tiered accountability so the strongest controls are aimed at the highest risk AI systems.

Target operating model: one governance foundation with sector overlays

This is the future-state architecture the projects are moving toward.



Brainstorming idea: Sector Deep-Dive Review Guide v1.1

Expand the sector checklist into deeper review guidance, especially for defense/national security and mission-critical environments.

What to add

What to look for during AI review.
What to audit and what evidence to request.
Applicable frameworks and compliance considerations.
Red flags, escalation triggers, and review frequency.
Sector-specific risk language for executives and auditors.

Defense / national security sector

Mission support, intelligence support, cyber defense triage, logistics, predictive maintenance, training simulation, operational planning.
Risks: classified data exposure, adversarial manipulation, overreliance, chain-of-command accountability, vendor risk.

Why this strengthens the portfolio

Shows my military background as a strategic advantage.
Moves the toolkit beyond generic compliance into mission-aware governance.
Connects AI governance to critical infrastructure, national security, and high-consequence operations.
Creates a natural bridge to AI security, incident response, and board-level risk reporting.

Version name: AI Governance & Security Toolkit v1.1 — Sector Deep-Dive Expansion

Future improvements by project

Each project can mature from portfolio artifact into a repeatable governance capability.

Project	Next improvement	Business value
Audit Playbook	Add GenAI red-team appendix, AI risk interview worksheet, vendor review worksheet, scoring dashboard.	Improves audit depth and certification readiness.
Governance Toolkit	Add AI inventory tab, control-framework mapping, risk scoring, automated dashboard charts, reviewer sign-off.	Turns workbook into a more complete governance workflow.
AI Security Project	Add test cases, monitoring examples, log evidence, prompt-injection scenarios, control validation screenshots.	Proves security controls work in practice.
American AI Act Concept	Add sector-specific chapters, risk tiers, oversight responsibilities, enforcement model, innovation-safe exemptions.	Sharpens policy credibility and executive usefulness.
Sector Deep-Dive v1.1	Build defense/national security, critical infrastructure, healthcare, finance, employment, education, public sector review pages.	Makes the toolkit sector-aware and more valuable to boards and regulated organizations.

Maturity roadmap: from portfolio to governance platform

A realistic path from current artifacts to a full-scale AI audit and governance system.

North Star: a unified AI governance system where organizations can inventory AI, assess risk, map controls, test evidence, identify gaps, and generate board-ready remediation plans.

Executive recommendation: build governance before AI scales out of control

1. **Create one AI inventory** — No AI system should be invisible.
2. **Rate AI risk by use case** — Oversight should match impact.
3. **Define controls and evidence** — Claims must become proof.
4. **Secure AI systems** — Governance fails if access, data, prompts, and logs are weak.
5. **Report to leadership** — Boards need trend, risk, exceptions, and remediation status.

Portfolio message: this is not just AI paperwork. It is business risk management for an AI-driven economy.

Sources and disclaimer

Reference foundation used for the deck and project framing.

NIST AI Risk Management Framework — risk management for AI systems and trustworthy AI characteristics.
European Commission EU AI Act pages — harmonized AI rules, staged implementation, high-risk system concepts, and trustworthy AI goals.
ISO/IEC 42001 — Artificial Intelligence Management System standard used as a certification-readiness reference point.
OWASP Top 10 for Large Language Model Applications 2025 — common LLM and generative AI security risks such as prompt injection, sensitive information disclosure, supply chain, and model denial-of-service concerns.
MITRE ATLAS — adversarial tactics, techniques, and knowledge base for AI-enabled systems.
Portfolio source artifacts: AI Audit Checklist & Certification Playbook; AI Governance & Security Toolkit; Securing an Enterprise AI Environment; American AI Act policy concept.

Disclaimer: This deck is an educational and portfolio presentation. It is not legal advice, an official compliance determination, or a substitute for qualified legal, security, privacy, compliance, or audit review.

Official source links: nist.gov/itl/ai-risk-management-framework • digital-strategy.ec.europa.eu/en/policies/regulatory-framework-ai • iso.org • owasp.org/www-project-top-10-for-large-language-model-applications • atlas.mitre.org